

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, members, and
Dr. Claudio Filippi, Deputy Secretary General;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, on the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD to Legislative Decree No. 196 of June 30, 2003, containing the "Code regarding the protection of personal data, containing provisions for the adaptation of the national legal system to Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, on the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC" (hereinafter "Code");

HAVING REGARD to Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Guarantor for the protection of personal data, approved by resolution No. 98 of April 4, 2019, published in G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc. web n. 9107633 (hereinafter "Guarantor Regulation No. 1/2019");

HAVING REGARD to the documentation on file;

HAVING REGARD to the observations made by the Secretary General pursuant to Article 15 of the Guarantor Regulation No. 1/2000 on the organization and functioning of the office of the Guarantor for the protection of personal data, on www.gpdp.it, doc. web n. 109880;

REPORTING Dr. Agostino Ghiglia;

PREMISE

1. The Complaint

With a complaint submitted to the Authority on XX, Ms. XX reported some violations of the regulations on the protection of personal data by the Provincial Health Authority of Enna - Health District of Nicosia (hereinafter "Health Authority").

In particular, Ms. XX represented and documented that, following a repeated request "for access to documents (...)" made to the Health Authority for "(...) the release of the minutes prepared by the Commission for severely ill patients that met in Nicosia on XX, to which her sister was subjected, (...) of which the (...) (complainant is) the support administrator," the Health Authority "communicated that 'the requested document prepared for release is no longer available in the office records.'"

2. The Investigative Activity and the Department's Assessments on Conduct and Treatment.

Notification of the violation referred to in Article 166, paragraph 5, of the Code

Following the complaint, the Office, with a note dated XX (prot. n. XX), requested the Health Authority - data controller - pursuant to Article 157 of the Code, to provide any useful information regarding the reported incident.

With a note dated XX (prot. n. XX), the Health Authority responded to the Authority's request, stating, among other things, that it had adopted organizational and technical measures and had "(...) provided training for all Personnel who, in various capacities, process personal data. The training is entrusted to the DPO of the entity."

Furthermore, the Health Authority stated that:

- “The ASP of Enna has worked to protect the confidentiality of users' data through a series of procedures that are already fully operational, as well as through a constant organizational programming of updates to the measures adopted. With resolution No. XX of XX, the regulation for the processing and protection of personal data was approved, which in particular in Article 18 contains the Directives regarding the retention and security of data. The aforementioned provision explicitly states that: ‘Personal data subject to processing must be stored and controlled, also in relation to the knowledge acquired based on technical progress, the nature of the data, and the specific characteristics of the processing, in such a way as to minimize, through the adoption of appropriate security measures, the risks of destruction or loss, even accidental, of the data themselves, unauthorized access, or processing not permitted or not compliant with the purposes of collection. Data processors are required to give the necessary instructions to the personnel in charge, so that the minimum security standard is constantly guaranteed in order to better ensure the right to privacy of users. Access to corporate archives must be controlled, and individuals who are admitted after closing hours must be identified and registered. With reference to corporate archives, the responsibility for their retention and security lies with the competent person for the data subject to processing.’ In compliance with the aforementioned provision, the Commission for severely ill patients prepares only one original in analog format and no digital copies are made; the retention of the original minutes along with the relevant files is entrusted to a member of the UVM, and in this specific case to the Social Assistant.”

of the District of Nicosia, which keeps the files in a special locked cabinet, the keys of which are stored in another drawer of the desk to which only the Assistant has access”;

- “Regarding the 'assessments made concerning the notification of a breach to the Authority pursuant to Article 33 of the Regulation (...) since the incident was confined to the individual concerned, of whom there is no certainty regarding the data breach, it was deemed that it did not pose a high risk to the rights of the individual involved or third parties, as stated in Regulation 679/2016 Article 33. Furthermore, to date, no disclosures of the involved data have been reported.”

In relation to the documentation on file and what was stated by the data controller, the Office, with act of XX (prot. n. XX), initiated, pursuant to Article 166, paragraph 5, of the Code, the procedure for the adoption of measures referred to in Article 58, paragraph 2, of the Regulation against the Health Company, inviting it to produce defensive writings or documents to the Authority, or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code, as well as Article 18, paragraph 1, Law No. 689 of November 24, 1981).

In particular, following what emerged, the Office considered that the Health Company violated Articles 5, paragraph 1, letter f) as well as Article 33 of the Regulation, respectively for failing to adopt appropriate organizational and technical measures to prevent the event that occurred (loss of the report drawn up by the Commission for severely ill patients of the Asp of Enna) and for failing to notify the breach to the Authority following the incident.

With note of XX (prot. n. XX), the data controller submitted a defensive memorandum, in which it was stated, among other things, that:

- “The buildings of the District of Nicosia have recently undergone renovation and modernization works that have required multiple relocations of furniture and staff. Consequently, as stated by Dr. Ghirlanda, Director of the Administrative U.O.C. Area North, it is likely that the file of Ms. XX was accidentally destroyed during these relocations, without however resulting in an unlawful dissemination of health-related personal data, as to date there are no communications in this regard”;

- “Considering what happened, in order to reconstruct the file without causing any harm to the patient, the patient was re-invited for a specific verification taking into account not only her current health status but also her health status at the time of the request. In doing so, an effort was made to limit the harm caused to the patient.”

The data controller highlighted that it has outlined a (...) “Data Protection Policy and has simultaneously identified the means and resources necessary for the policy to be understood,

implemented, and maintained” and adopted organizational and technical measures within the Health Company itself.

3. Outcome of the investigative activity

With reference to the issue raised, it is noted that “personal data” means “any information relating to an identified or identifiable natural person ('data subject')” and “health data” refers to “personal data related to the physical or mental health of a natural person, including the provision of health care, which reveals information about their health status” (Article 4, paragraph 1, numbers 1 and 15 of the Regulation). These latter data deserve greater protection since the context of their processing could create significant risks to fundamental rights and freedoms (Recital No. 51). The data processed in the case at hand, pertaining to data contained in a report drawn up by the medical commission for “severely ill patients” of the Health District of Nicosia concerning Ms. XX - of whom the sister, the complainant in this instance, acts as a support administrator - are therefore classified as health data.

The data controller is then required to comply with the principles regarding data protection, including the principle of “integrity and confidentiality,” according to which personal data must be “processed in a manner that ensures appropriate security (...), including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage” (Article 5, paragraph 1, letter f) of the Regulation).

The adequacy of such measures must be assessed by the data controller in order to “ensure a level of security appropriate to the risk,” taking into account, among other things, “the nature, scope, context, and purposes of the processing, as well as the likelihood and severity of the risk to the rights and freedoms of natural persons” (Article 32 of the Regulation).

If a personal data breach occurs, the data controller has the obligation to notify such “(...) breach to the competent supervisory authority pursuant to Article 55 without undue delay, and where feasible, within 72 hours of becoming aware of it, unless the breach is unlikely to result in a risk to the rights and freedoms of natural persons” (Article 33 of the Regulation).

Taking note of what is represented in the documentation on file and in the defensive memorandum, highlighting that the processing of personal data must occur in compliance with the aforementioned regulations, the following observations are made.

3.1 Failure to comply with the principles of “integrity and confidentiality” of personal data (art. 5, par. 1, lett. f) of the Regulation) and security obligations related to processing (art. 32 of the Regulation)
Based on the elements in the records produced by the complainant and acquired following the investigative activity, although the Health Authority declared that it had adopted technical and organizational measures in the response provided to the Authority on XX (prot. n. XX), as well as in the defense memorandum of XX, it was found, in relation to the matter subject to the complaint, that the measures implemented were inadequate, in violation of what is required by the Regulation, for which the data controller is required to adopt “appropriate technical and organizational measures to ensure (both) a level of security appropriate to the risk” (art. 32, par. 1) of accidental loss or destruction of the document in question in this proceeding as well as “the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident” (art. 32 par. 1, lett. c)).

3.2 Failure to notify a personal data breach to the supervisory authority (art. 33 of the Regulation)

With regard to what was declared by the Health Authority concerning the assessments made to determine whether or not to notify the breach to the Guarantor, pursuant to art. 33 of the Regulation, based on which it was deemed that the incident “(...) being (...) confined to the sole person of the data subject, of which there is no certainty of data breach (...) did not pose a high risk to the rights of the involved person or third parties (...)”, it is highlighted that the aforementioned provision requires such notification of breach to the Guarantor “(...) unless it is unlikely that the personal data breach presents a risk (even if not high) to the rights and freedoms of natural persons” and that the loss of personal data, concerning the availability of the same, constitutes a case of breach (cf. art. 4, par. 1, point 12, of the Regulation and cf. points 17-19 of the “Guidelines No. 9/2022 on the notification of personal data breaches pursuant to the GDPR” adopted by the European Data Protection Committee on March 28,

2023).

4. Conclusions.

In light of the evaluations mentioned above, taking into account the statements made by the data controller during the investigation and considering that, unless the act constitutes a more serious crime, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable pursuant to art. 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or exercise of the powers of the Guarantor", the elements provided by the data controller in the aforementioned defense memorandum, although deserving of consideration, do not allow for overcoming the observations notified by the Office with the aforementioned initiation act of the proceeding, nor do any of the cases provided for by art. 11 of the Guarantor Regulation No. 1/2019 apply.

Therefore, all that has been stated, based on the records and the statements provided, in relation to the matter in question, also based on the provision of the Regulation of a "general responsibility" on the part of the data controller also concerning the preparation of appropriate technical and organizational measures from a security perspective (art. 4, par. 1, point 7, of the Regulation; art. 5, par. 2 and art. 24, par. 1, of the Regulation for which "the data controller implements appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is carried out in accordance with this Regulation", as well as Considering No. 74 of the same Regulation, in relation to the so-called principle of "accountability"), the illegality of the processing carried out by the Health Authority, the data controller, is established, which:

- processed data relating to the health of the patient, of whom the complainant is the support administrator, in violation of the principles of "integrity and confidentiality" of personal data and security obligations related to processing, in violation of art. 5, par. 1, lett. f) and 32 of the Regulation;
- did not notify the personal data breach to the supervisory authority, in relation to the matter subject to the complaint, in violation of art. 33 of the same Regulation.

In this context, considering that the data controller has acted in order to "(...) reconstruct the file without causing any harm to the patient, (...) (reconvening) the patient (and) conducting a specific verification also taking into account the health status at the time of the request and not only the current one (...) (and trying) to limit the harm caused to the patient", the conditions for the adoption of corrective measures pursuant to art. 58, par. 2, of the Regulation do not exist.

Finally, it is believed that the conditions referred to in art. 17 of the Guarantor Regulation No. 1/2019 are met.

5. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (arts. 58, par. 2, lett. i and 83 of the Regulation; art. 166, par. 7, of the Code). The violation of arts. 5, par. 1, lett. f) and 32 of the Regulation, as well as of art. 33 of the same Regulation, caused by the data controller, is subject to the application of the administrative pecuniary sanction referred to in art. 83, parr. 4 and 5, of the Regulation.

The Authority, pursuant to Article 58, paragraph 2, letter i) of the Regulation and Article 166 of the Code, has the power to impose an administrative monetary fine as provided for in Article 83 of the Regulation, through the adoption of an injunction order (Article 18 of Law No. 689 of November 24, 1981), in relation to the processing of personal data carried out by the Health Authority, the unlawfulness of which has been established as outlined above.

In this case, it has been assessed that the data controller has engaged in two distinct behaviors, consisting of the failure to notify the data breach to the Supervisory Authority pursuant to Article 33 of the Regulation, on one hand, and the failure to comply with the principles of "integrity and confidentiality" of personal data (Article 5, paragraph 1, letter f) and the security obligations related to processing (Article 32 of the Regulation), on the other hand, which must be considered separately for the purposes of quantifying the applicable administrative fines. In calculating the administrative fine, in accordance with Article 83, paragraph 3, of the Regulation, the violations referred to in point 3.1 of the above paragraph 3 are instead considered together, as they relate to a single processing operation (Guidelines 04/2022 on the calculation of administrative monetary fines pursuant to the GDPR -

Version 2.0 adopted on May 24, 2023, paragraph 3.1.2, point 39).

5.1 Failure to comply with the principles of "integrity and confidentiality" of personal data (Article 5, paragraph 1, letter f) of the Regulation) and the security obligations related to processing (Article 32 of the Regulation)

With reference to the violation of Article 5, paragraph 1, letter f) of the Regulation, as well as Article 32 of the same Regulation, both subject to the administrative monetary fine provided for in Article 83, paragraphs 5 and 4, of the same Regulation, based on Article 83, paragraph 3, of the Regulation - as illustrated above - the total amount of the fine is to be quantified taking into account the maximum so-called "static" limit established by Article 83, paragraph 5, of the Regulation, equal to the maximum limit of €20,000,000.00.

Regarding the level of severity of the violation, based on the elements referred to in Article 83, paragraph 2, letters a), b), and g) of the Regulation, it is to be considered high, taking into account the type of documentation that was lost, which included, among other things, data related to health (minutes drawn up by the Commission for severely ill patients of the Health District of Nicosia of the Health Authority) and the level of damage suffered, considering that "the failure to release the minutes drawn up on XX prevented the applicant from challenging the same before the Judicial Authority, being unaware of its content; the undersigned has only deduced that the requested benefit was not recognized, without coming to know, even today, the reasons." This, despite the absence of intent and taking into account the circumstances presented by the data controller, in which such a document was presumably lost (renovation works at the headquarters of the Health Authority).

Further elements provided for by Article 83, paragraph 2, of the Regulation are also considered, in particular, that:

- the data controller acted in order to "(...) reconstruct the file, (...) (reconvening) the patient (and) conducting a specific verification taking into account also the state of health at the time of the request and not only the current one (...) (and trying) to circumscribe the harm caused to the patient" (Article 83, paragraph 2, letters c) and f) of the Regulation);
- no relevant violations were committed by the data controller (Article 83, paragraph 2, letter e) of the Regulation);
- the Authority became aware of the violation following a complaint from the interested party, formulated on their behalf by the support administrator (Article 83, paragraph 2, letter h) of the Regulation).

In light of the above elements, evaluated in their entirety, for the conduct of the data controller in the matter in question in violation of Articles 5, paragraph 1, letter f) and 32 of the Regulation, it is deemed appropriate to determine the amount of the monetary fine at €6,000.00 (six thousand/00).

5.2 Failure to notify the personal data breach to the Supervisory Authority (Article 33 of the Regulation)

With reference to the violation of Article 33 of the Regulation subject to the administrative monetary fine provided for in Article 83, paragraph 4, of the same Regulation, the total amount of the fine is to be quantified taking into account the maximum so-called "static" limit established by the Regulation, equal to the maximum limit of €10,000,000.00.

Regarding the level of severity of the violation, based on the elements referred to in Article 83, paragraph 2, letters a), b), and g) of the Regulation, it is to be considered medium, although there is an absence of intent and the case involved only one interested party. This, taking into account the assessment made by the Health Authority regarding the severity of the event that occurred, as it deemed that it did not "pose a high risk to the rights of the person involved or third parties (...)", whereas Article 33 of the Regulation establishes the obligation to notify a personal data breach to the Supervisory Authority "(...) unless it is unlikely that the personal data breach presents a risk (even if not high) to the rights and freedoms of natural persons." The loss of personal data, as highlighted above, constitutes a case of breach that must be notified to the Authority (cf. Article 4, paragraph 1, point 12, of the Regulation and points 17-19 of the "Guidelines No. 9/2022 on the notification of personal data

breaches pursuant to the GDPR" adopted by European Data Protection Committee on March 28, 2023).

In relation to the additional elements provided for in Article 83, paragraph 2, of the Regulation, it is considered that:

- no relevant violations have been committed by the data controller (Article 83, paragraph 2, letter e) of the Regulation);
- the Authority became aware of the violation following a complaint from the data subject, made on their behalf by the support administrator (Article 83, paragraph 2, letter h) of the Regulation).

In light of the above elements, assessed as a whole, regarding the conduct of the data controller in the matter in question in violation of Article 33 of the Regulation, it is deemed appropriate to determine the amount of the administrative fine at €2,000.00 (two thousand).

In light of the above, considering that the sanction must be "effective, proportionate, and dissuasive in each individual case" pursuant to Article 83, paragraph 1 of the Regulation, the total quantification of the administrative sanction amounts to €8,000.00 (eight thousand).

5.3 Additional assessments and accessory sanction of the publication of the injunction order

Considering the nature of the health data whose processing is the subject of the matter in question, the damage suffered by the data subject, and the failure to notify the Authority of the violation, it is also deemed that pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Garante Regulation No. 1/2019, the publication of this section, containing the injunction order, on the Garante's website should proceed.

ALL OF THE ABOVE CONSIDERED, THE Garante

pursuant to Articles 57, paragraph 1, letter f) and 83 of the Regulation, notes the unlawfulness of the processing carried out by the Provincial Health Authority of Enna, located in Enna, Viale Armando Diaz, 7 - postal code 94100 - Tax Code: 01151150867 in the terms outlined in the reasoning, for the violation of Articles 5, paragraph 1, letter f) and 32 of the Regulation, as well as Article 33 of the same Regulation;

ORDERS

pursuant to Articles 58, paragraph 2, letter i) the same Provincial Health Authority of Enna, as the data controller, to pay the sum of €8,000.00 (eight thousand) as an administrative pecuniary sanction for the violations indicated in this provision;

THEREFORE ENJOINS

the aforementioned data controller to pay the sum of €8,000.00 (eight thousand) according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts pursuant to Article 27 of Law No. 689/198. It is noted that pursuant to Article 166, paragraph 8 of the Code, the possibility for the offender to settle the dispute by paying - according to the methods indicated in the annex - an amount equal to half of the imposed sanction within the term provided for the filing of the appeal as indicated below remains unaffected.

DISPOSES

- pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Garante Regulation No. 1/2019, the publication of the injunction order on the Garante's website;
- pursuant to Article 154-bis, paragraph 3, of the Code and Article 37 of the Garante Regulation No. 1/2019, the publication of this provision on the Authority's website;
- pursuant to Article 17 of the Garante Regulation No. 1/2019, the annotation of the violations and the measures adopted in accordance with Article 58, paragraph 2 of the Regulation, in the internal register of the Authority provided for by Article 57, paragraph 1, letter u) of the Regulation.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree

No. 150/2011, an appeal against this provision may be made to the ordinary judicial authority, with a petition filed at the ordinary court of the place identified in the same Article 10, within thirty days from the date of communication of the provision itself, or sixty days if the appellant resides abroad.

Rome, December 19, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Ghiglia

THE DEPUTY SECRETARY GENERAL

Filippi